KOVERT

Sikkerhet i iOS

Vetle Hjelle

~# whoami

- Pentester i 4 år
- Jobbet i Kovert siden mai
- Host for podcasten 5h3llcast
- bordplate.no
- twitter.com/bordplate

KOVERT

Kovert

- Startet januar i år
- Spesialister på IT-sikkerhetstesting
- 3 ansatte
- Hovedsaklig pentestoppdrag
- kovert.no

Hva er iOS

KOVERT

Kjernen til iOS

- Basert på Darwin
  - Hybrid Kernel med XNU/Mach
  - BSD
- For det meste POSIX-kompatibel
- ARM64
- Kildekode tilgjengelig på opensource.apple.com

KOVERT

Boot-up

- Boot ROM
  - "Hardware root of trust"
  - Kodes på fabrikken, kan ikke endres
  - Apple's Root Certificate Authority (CA)
  - Dekrypterer og starter iBoot

KOVERT

Boot-up

- iBoot
  - Low-Level Bootloader
  - 2 steg med iBoot
  - Ansvarlig for å laste iOS sin kernel

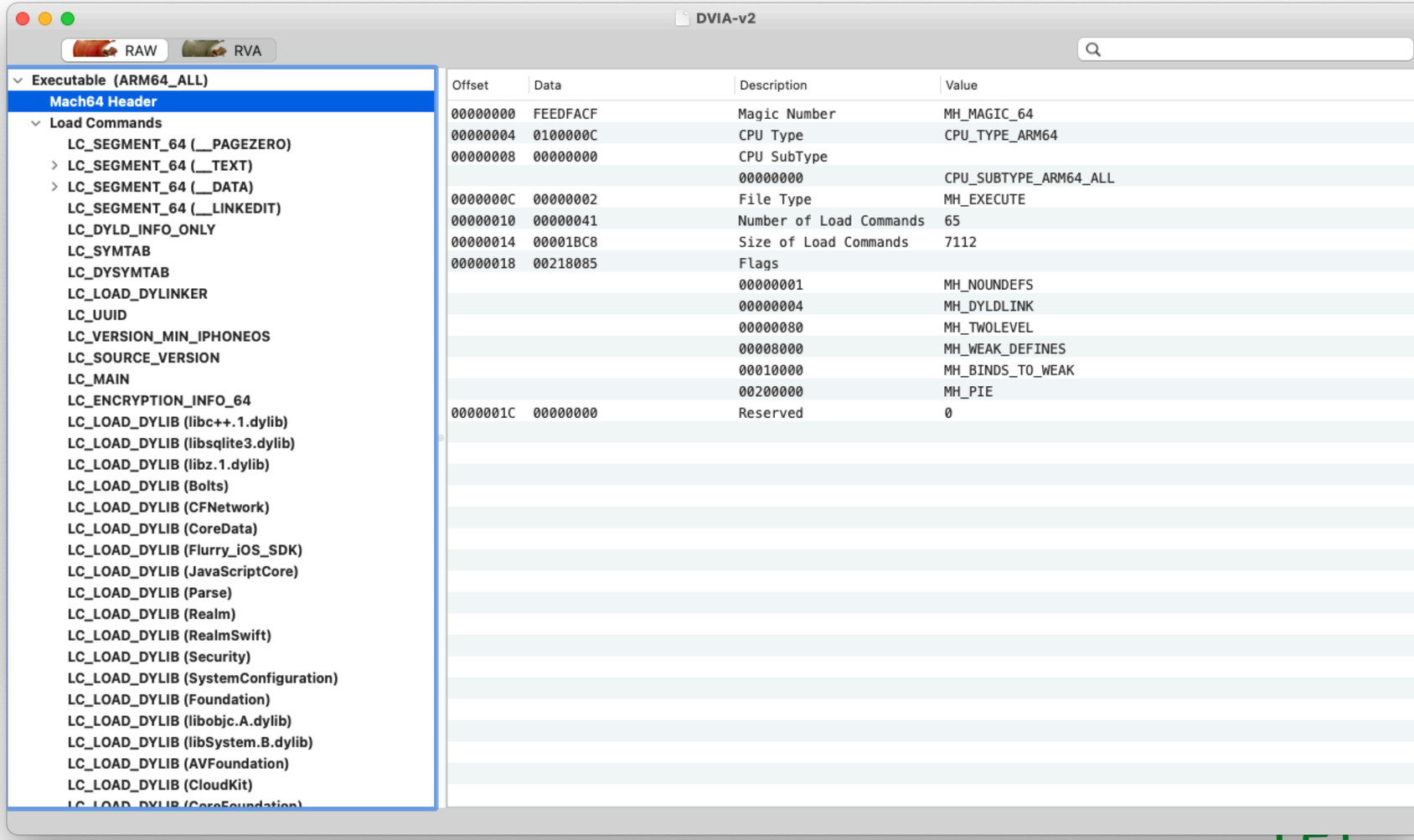
KOVERT

Applikasjoner og distribusjon

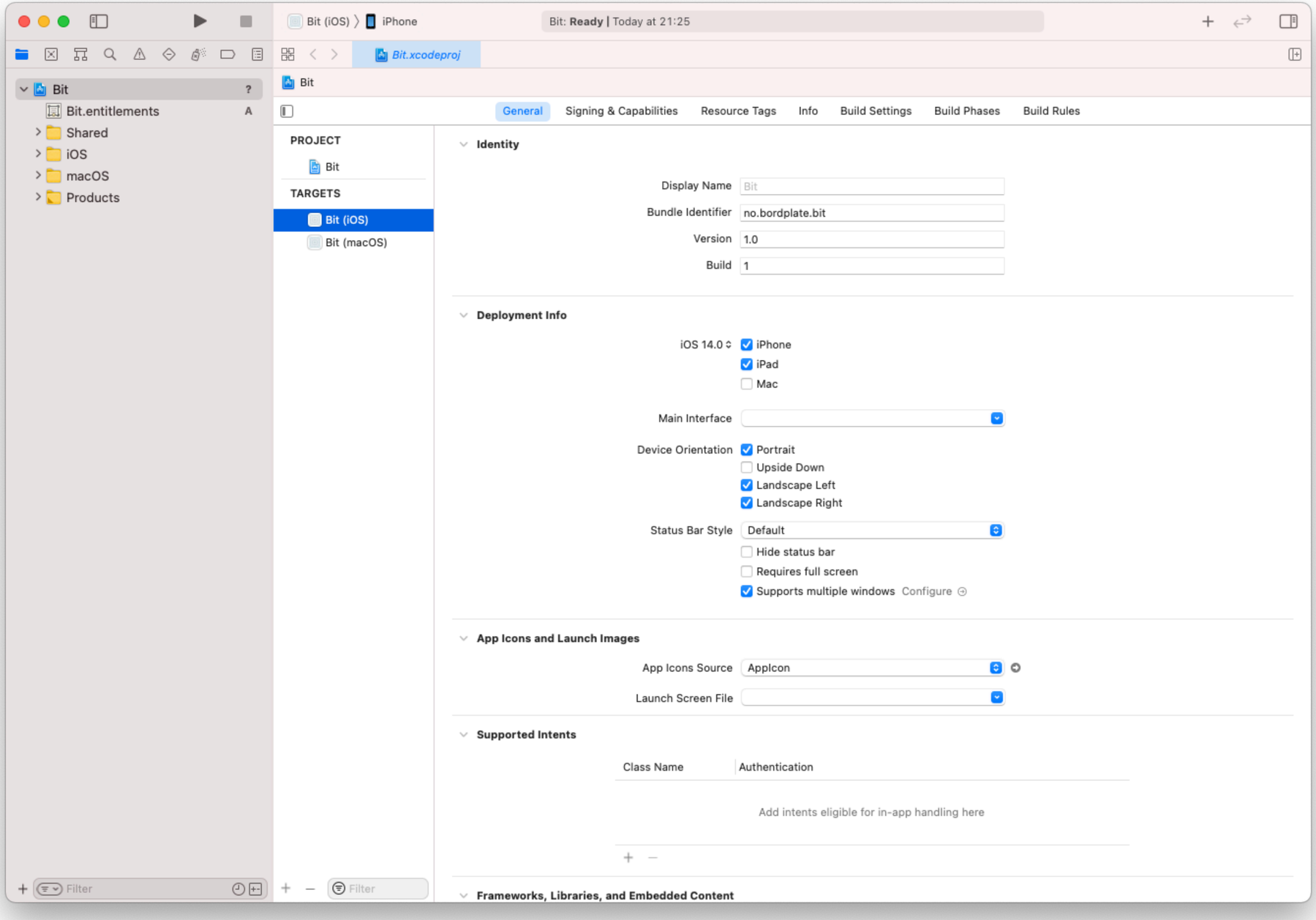
KOVERT

Applikasjoner

- Mach-O
- Swift og Objective-C
  - Xcode



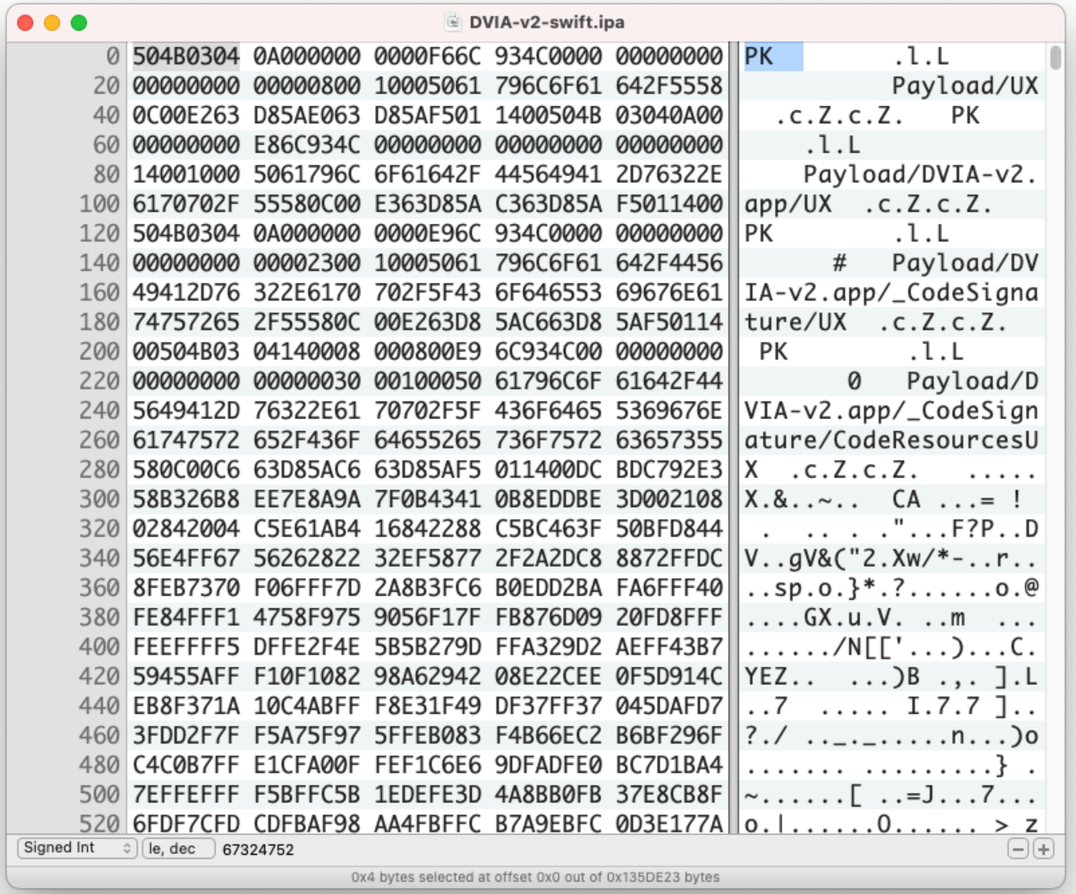
KOVERT


Bit (iOS) iPhone
Bit: Ready | Today at 21:25
Bit.xcodeproj
Bit
Bit.entitlements
Shared
iOS
macOS
Products
PROJECT
Bit
TARGETS
Bit (iOS)
Bit (macOS)
General
Signing & Capabilities
Resource Tags
Info
Build Settings
Build Phases
Build Rules
Identity
Display Name
Bundle Identifier
no.bordplate.bit
Version
1.0
Build
1
Deployment Info
iOS 14.0
iPhone
iPad
Mac
Main Interface
Device Orientation
Portrait
Upside Down
Landscape Left
Landscape Right
Status Bar Style
Default
Hide status bar
Requires full screen
Supports multiple windows
Configure
App Icons and Launch Images
App Icons Source
AppIcon
Launch Screen File
Supported Intents
Class Name
Authentication
Add intents eligible for in-app handling here
Frameworks, Libraries, and Embedded Content
Filter

KOVERT

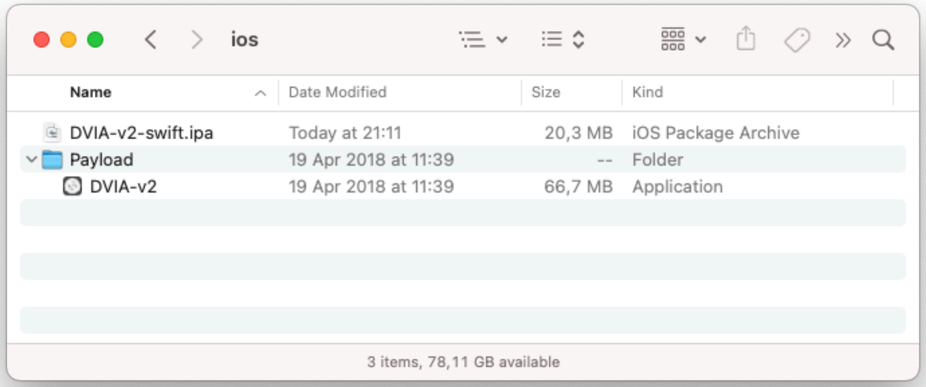
.IPA

- ZIP-fil
- Info.plist
  - Permissions som kamera, posisjon, etc.



KOVERT

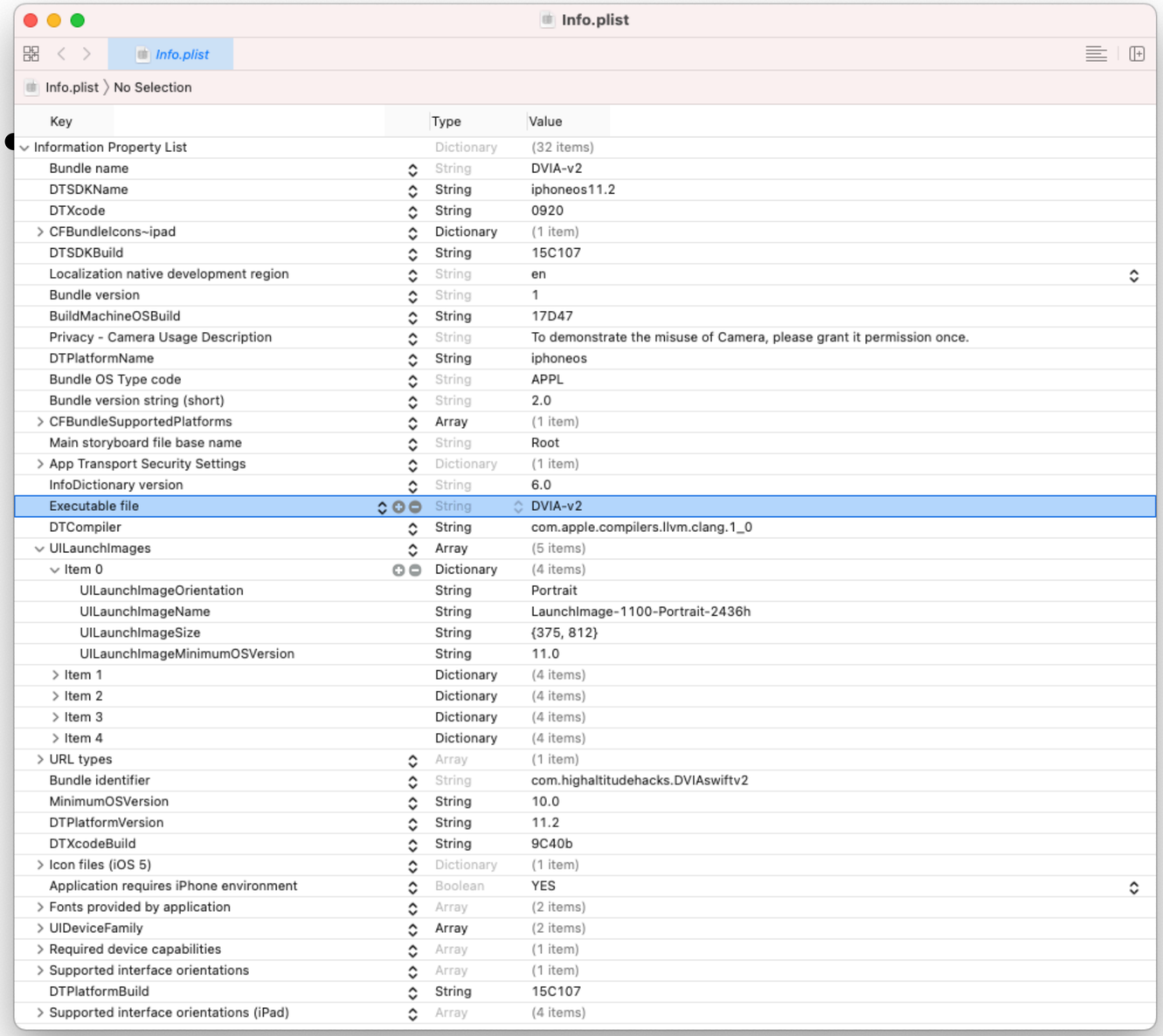
- ZIP-fil
- Info.plist
  - Permissions som kamera, posisjon, etc.



.IP

KOVERT

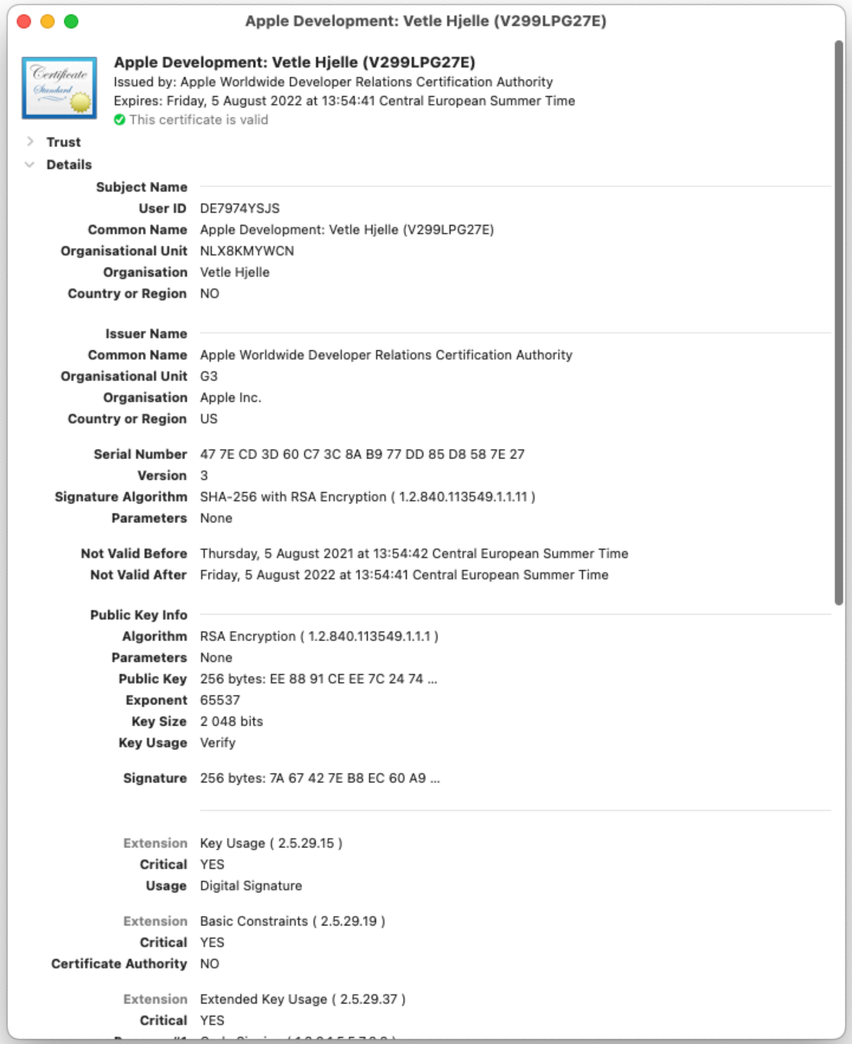
- ZIP-fil
- Info.plist
  - Permissions som kamera, posisjon, etc.
- Alle ressurser appen bruker



KOVERT

Kodesignering

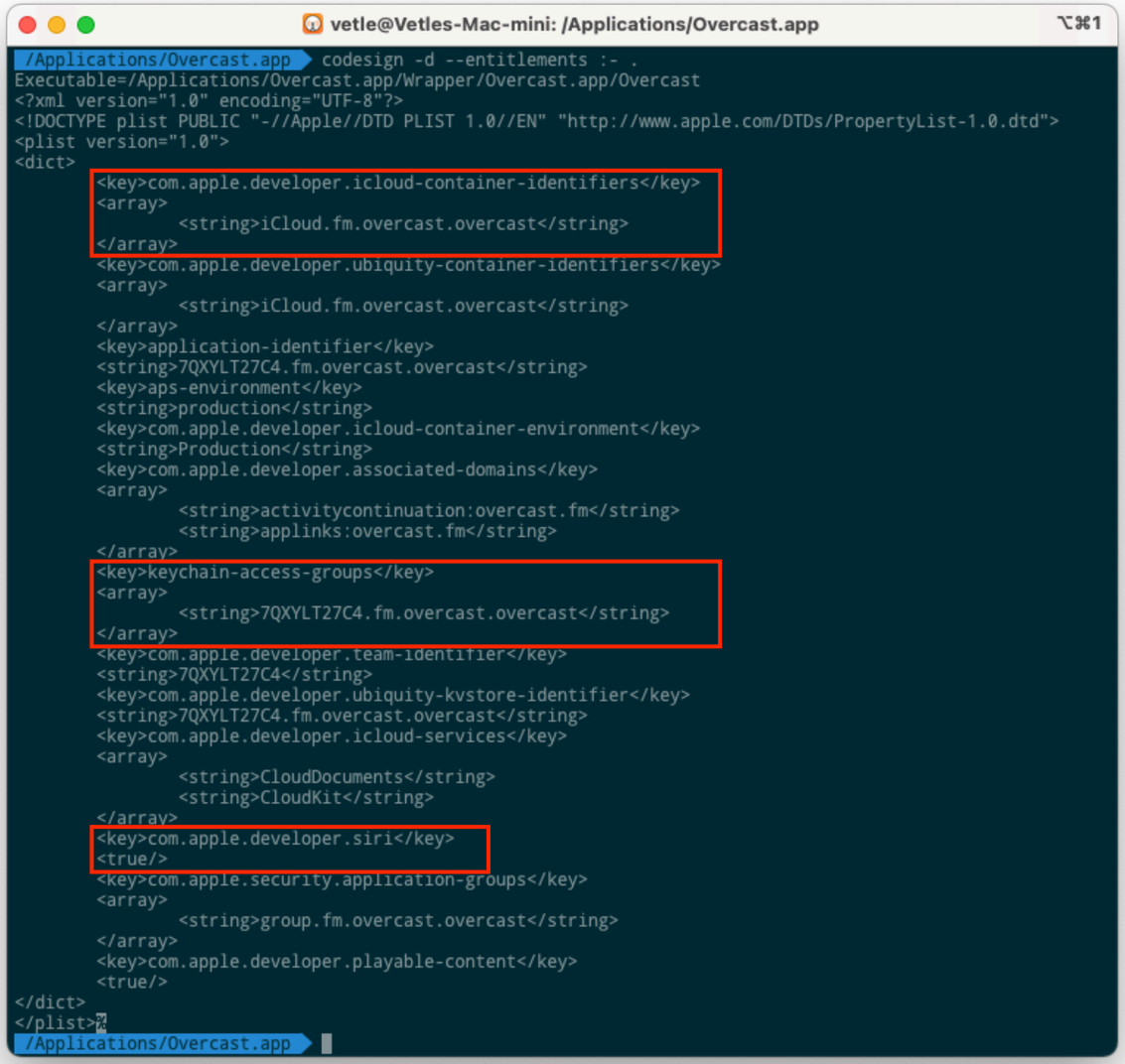
- Må kjøpes fra Apple
- Krypterer ikke



KOVERT

Entitlements

- Rettigheter/priveleger for apper



KOVERT

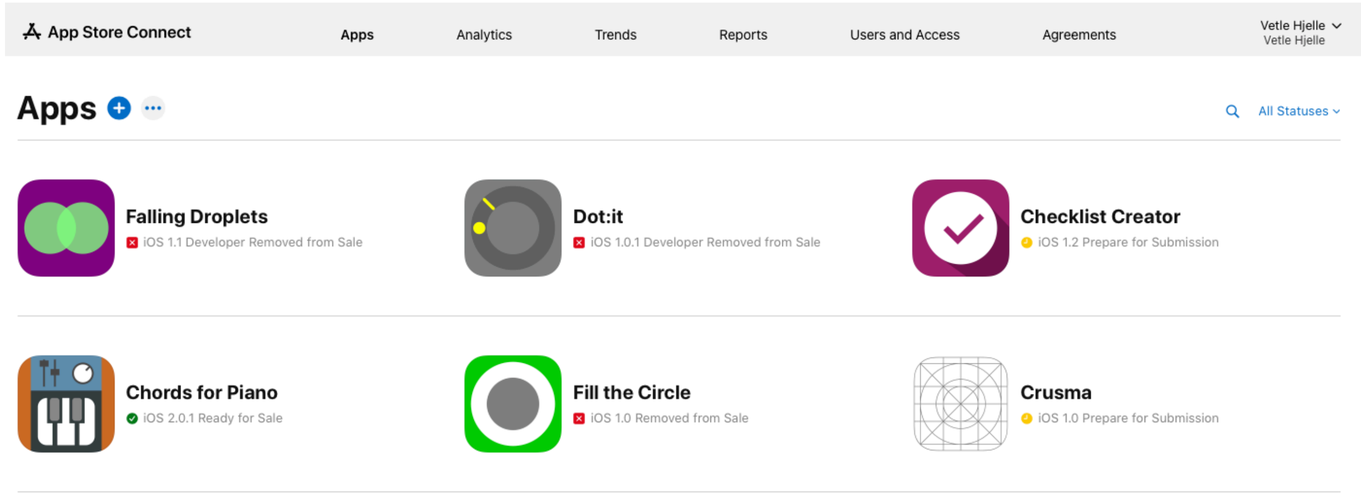
Distribusjon

- App Store
- In-house – Enterprise
- Ad-hoc
- Custom apps
- (TestFlight)

KOVERT

Distribusjon

- Kompiler appen for release
- Kodesigner
- Last opp til App Store Connect
- Apple krypterer appen din



KOVERT

Sikkerhetsmekanismer

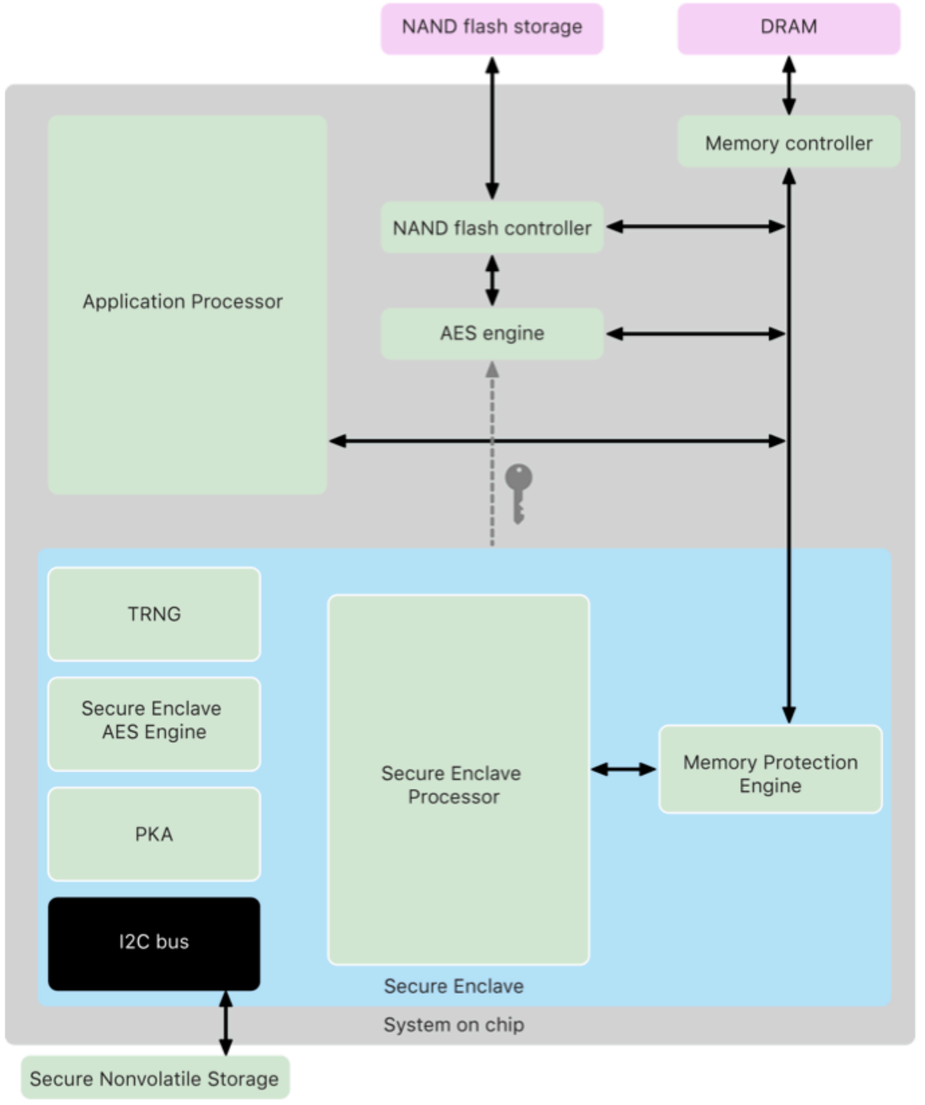
KOVERT

Hardware

- Secure Enclave
- Kernel Integrity Protection
- Fast Permission Restrictions
- System Coprocesor Integrity Protection
- Pointer Authentication Codes
- Page Protection Layer

KOVERT

Secure Enclave



The Secure Enclave components.

Delays between passcode attempts

Attempts	Delay enforced
1–4	None
5	1 minute
6	5 minutes
7–8	15 minutes
9	1 hour

https://manuals.info.apple.com/MANUALS/1000/MA1902/en_US/apple-platform-security-guide.pdf

KOVERT

Kernel Integrity Protection

- Låser kernel-minne etter boot
- Hardware som aktiverer KIP låses etter boot
- Stopper:
  - Exec mapping utfor beskyttet minneregion
  - Write mapping innenfor beskyttet minneregion

KOVERT

Fast Permission Restrictions

- Raskt bytte av permissions
- Mitigerer angrep mot Just-in-time (JIT) kompilert kode
  - Med mye lavere overhead

KOVERT

System Coprocessor Integrity Protection

- Coprosessor-sikkerhet
- Fungerer likt som KIP
  - Låser minnet til prossesorens firmware
- Secure Enclave gjør det selv

KOVERT

Pointer Authentication Codes

0x1100	Some text
0x1110	Other text
0x1120	More text
0x1130	Even more text
0x1140	Hello, world!

KOVERT

Pointer Authentication Codes

- Signerer pointere
- Beskytter mot Return-Oriented Programming

KOVERT

Page Protection Layer

- KIP for vanlige applikasjoner
- Aktiveres etter app har startet og blitt verifisert
- Ulikt KIP kan dette slås av og på fra kernel

KOVERT

Software

- Address-Space Layout Randomization (ASLR)
- Stack canaries
- W^X/No-Execute

KOVERT

Address-Space Layout Randomization

- Krever Position-Independent Executables
- kASLR i kernel

KOVERT

Stack canaries

- "Kanari"-verdi i stacken
- Hvis den er borte stopper appen

KOVERT

W^X / Execute Never

- Enten skrivbart eller eksekverbart
- Ikke lov å skrive til minne som kan eksekveres

KOVERT

Datakryptering på disk

Data Protection – "Data at rest"

- Hver fil har unik nøkkel
- Filnøkler kryptert med "class-key"
- Class-key må være dekryptert for å dekryptere filnøkkel
- Alt skjer i Secure Enclave

Class	Protection type
Class A: Complete Protection	(NSFileProtectionComplete)
Class B: Protected Unless Open	(NSFileProtectionCompleteUnlessOpen)
Class C: Protected Until First User Authentication *Note:* macOS uses a volume key to recreate FileVault protection characteristics.	(NSFileProtectionCompleteUntilFirstUser Authentication)
Class D: No Protection *Note:* Not supported on macOS.	(NSFileProtectionNone)

https://manuals.info.apple.com/MANUALS/1000/MA1902/en_US/apple-platform-security-guide.pdf

Keychain

- Private keys, passord, SIM PIN, etc.
- Ganske likt Data Protection

Availability	File data protection	Keychain data protection
When unlocked	NSFileProtectionComplete	kSecAttrAccessibleWhenUnlocked
While locked	NSFileProtectionCompleteUnlessOpen	N/A
After first unlock	NSFileProtectionCompleteUntilFirstUserAuthentication	kSecAttrAccessibleAfterFirstUnlock
Always	NSFileProtectionNone	kSecAttrAccessibleAlways
Passcode enabled	N/A	kSecAttrAccessibleWhenPasscodeSetThisDeviceOnly

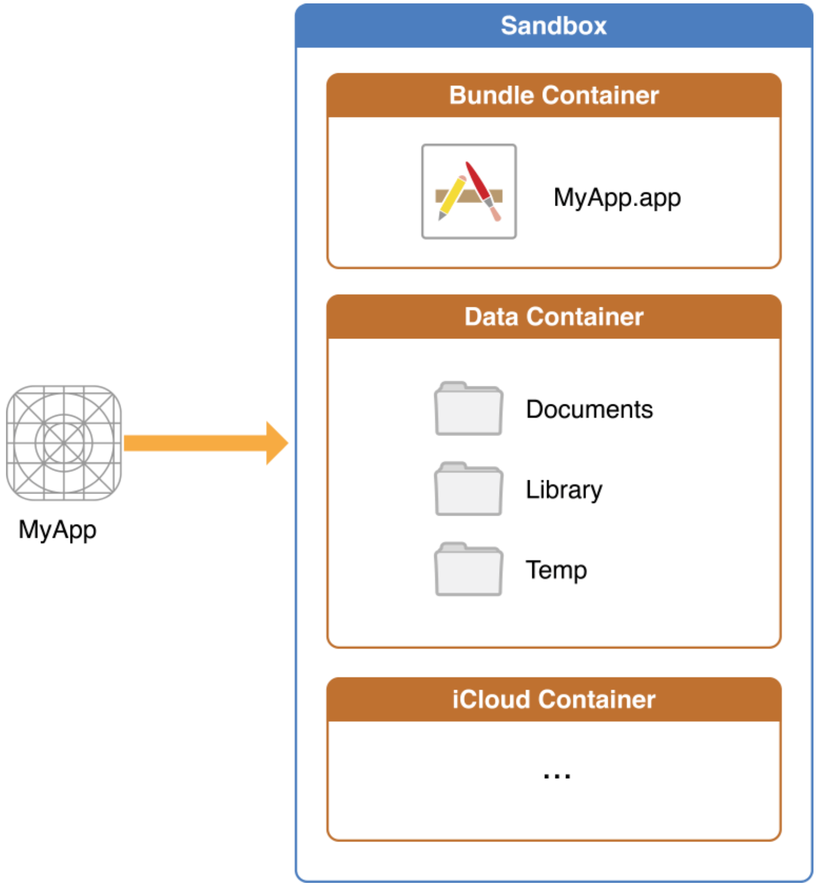
KOVERT

Applikasjonssikkerhet

KOVERT

Sandbox

- Begrenser apper til kun sine egne filer
- Låser tilgang til kamera, GPS, etc.
- "mobile"-brukeren kjører apper



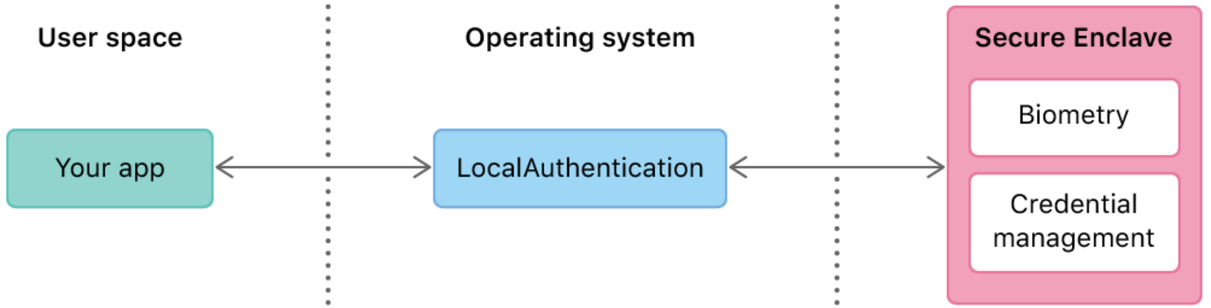
Permissions apper kan be om:
- Contacts
- Calendars
- Reminders
- Photos
- Motion activity and fitness
- Location Services
- Apple Music
- Your music and video activity
- Microphone
- Camera
- HomeKit
- Health
- Speech recognition
- Bluetooth sharing
- Your media library

KOVERT

Lokal autentisering

Touch ID og Face ID

```swift
var context = LAContext()

let reason = "Log in to your account"
context.evaluatePolicy(.deviceOwnerAuthentication, localizedReason: reason ) { success, error in


    if success {


        // Move to the main thread because a state update triggers UI changes.
        DispatchQueue.main.async { [unowned self] in
            self.state = .loggedin
        }


    } else {
        print(error?.localizedDescription ?? "Failed to authenticate")


        // Fall back to a asking for username and password.
        // ...
    }
}
```



KOVERT

Sårbarhetskategorier

- Datalagring og personvern
- Kryptografi
- Autentisering og sesjonshåndtering
- Nettverkskommunikasjon
- Plattforminteraksjon

https://github.com/OWASP/owasp-masvs

KOVERT

Lokal lagring

- Bruk riktig Data Protection class
- Ikke logg sensitiv data til konsollen
- Deaktiver autokorrekt for sensitive felt
- Gjem sensitiv data når appen minimeres

KOVERT

Kryptografi

- Ikke hardkod krypteringsnøkler
- Ikke rull din egen kryptografi

KOVERT

Autentisering og sesjonshåndtering

- Autentiser brukere eksternt
- Bruk sesjonstokens
- Ikke stol blindt på LocalAuthentication
- 2-faktorautentisering

KOVERT

Nettverkskommunikasjon

- Vi er ferdig med plain-text kommunikasjon, HTTPS alltid
- Bruk certificate-pinning
- Bruk sikre kanaler for autentisering/recovery

KOVERT

Plattforminteraksjon

- Kun be om tilganger du faktisk trenger
- All input må valideres
- Deaktiver JavaScript i WebViews

KOVERT

Verktøy

- Frida – frida.re
- OWASP Crackmes – github.com/OWASP/owasp-mstg/tree/1.1.3/Crackmes
- Damn Vulnerable iOS App – damnvulnerableiosapp.com

KOVERT

Bilder

- Coverbilde
  - https://unsplash.com/photos/VXcJYnVjev8
- Hva er iOS
  - https://unsplash.com/photos/DQdD9skk-mQ
- Applikasjoner og distribusjon
  - https://unsplash.com/photos/XDIFhtsH1CI
- Applikasjonssikkerhet
  - https://unsplash.com/photos/7C8c-7fwk34

KOVERT